IT4010 Research Project – 2026 Jul

Topic Assessment Form

V2.2

Project ID: J26-SE-347

1. Topic (12 words max)

Secure Multi-Tenant Natural Language Interface for Database Querying

2. Research group the project belongs to

CoEAI - Centre of Excellence for AI

3. Specialization of the project belongs to

Software Engineering (SE)

4. If a continuation of a previous project:

Project ID	
Year	

5. Brief description of the research problem including references (300 words max) – references not included in word count.

Context: Relational databases contain critical enterprise data, but non-technical users struggle to extract insights without custom-built dashboards [1]. Consequently, organizations waste massive engineering resources developing specific UI features for every customer data request.

Vulnerability: While naive AI text-to-SQL tools theoretically bridge this gap, deploying them in a multi-tenant SaaS environment introduces severe security flaws. Research confirms that LLM-integrated systems remain critically vulnerable to untrusted inputs and prompt injection attacks [3], particularly when input separation and structured query defenses are absent [4].

Problem: Exposing AI-driven database generation to external customers opens the door to catastrophic prompt injection attacks [3], unauthorized cross-tenant data leakage [5], and the accidental execution of destructive commands. Furthermore, existing systems lack a secure protocol for handling authorized write actions and often expose Personally Identifiable Information (PII) to unauthorized viewers.

Challenge: Bridging this usability gap allowing businesses to offer dynamic, natural language data retrieval without compromising strict enterprise access control, data isolation [5], [6], and read-only governance is a highly complex architectural challenge demanding deterministic security mechanisms.

Alignment: Addressing this challenge aligns with the Artificial Intelligence and Cybersecurity research clusters, supporting three SDGs:

- **SDG 8 (Decent Work and Economic Growth):** Eliminates custom dashboard overhead, enhancing workforce productivity.
- **SDG 9 (Industry, Innovation, and Infrastructure):** Delivers a secure, AI-powered multi-tenant middleware platform, advancing scalable data infrastructure [6].
- **SDG 16 (Peace, Justice, and Strong Institutions):** Enforces deterministic access control guarantees and federated identity governance [5], [6], promoting transparent and accountable data institutions.

References:

[1] D. Gao, H. Wang, Y. Li, X. Sun, Y. Qian, B. Ding, and J. Zhou, "Text-to-SQL Empowered by Large Language Models: A Benchmark Evaluation," *Proc. VLDB Endowment*, vol. 17, no. 5, pp. 1132–1145, 2024.

[2] M. Pourreza and D. Rafiei, "DIN-SQL: Decomposed In-Context Learning of Text-to-SQL with Self-Correction," in *Adv. Neural Inf. Process. Syst. 36 (NeurIPS)*, 2023.

[3] Y. Liu, Y. Jia, R. Geng, J. Jia, and N. Z. Gong, "Formalizing and Benchmarking Prompt Injection Attacks and Defenses," in *33rd USENIX Security Symp.*, 2024.

[4] S. Chen, J. Piet, C. Sitawarin, B. Alomair, and D. Wagner, "StruQ: Defending Against Prompt Injection with Structured Queries," in *34th USENIX Security Symp.*, 2025.

[5] P. Pappachan, S. Zhang, X. He, and S. Mehrotra, "Preventing Inferences Through Data Dependencies on Sensitive Data," *IEEE Trans. Knowl. Data Eng.*, vol. 36, no. 10, pp. 5308–5327, 2024.

[6] W. Lang *et al.*, "Multi-Tenant Cloud Data Services: State-of-the-Art, Challenges and Opportunities," in *Proc. ACM SIGMOD Int. Conf. Manage. Data*, 2022.

[7] P. Maddigan and T. Susnjak, "Chat2VIS: Generating Data Visualizations via Natural Language Using ChatGPT, Codex and GPT-3 Large Language Models," *IEEE Access*, vol. 11, pp. 45181–45193, 2023.

[8] H. Kim, S. Kim, S. Min, *et al.*, "Contrastive Time-Series Anomaly Detection," *IEEE Trans. Knowl. Data Eng.*, vol. 36, no. 10, pp. 5053–5065, 2024.

6. Brief description of Existing Research and Systems (300 words max)

Summary of Existing Research: Commercial BI tools successfully utilize LLMs to translate natural language into visual insights [7]. However, they lack the architectural safeguards required for secure, multi-tenant embedded analytics [6]. Academically, advanced benchmarks drive schema-aware Text-to-SQL research [1], with frameworks like DIN-SQL achieving high accuracy through decomposed in-context learning and self-correction [2]. Concurrently, cybersecurity research highlights severe prompt injection risks [3], driving the need for structured query defenses [4].

Gaps and Limitations Identified: Most existing work emphasizes isolated query generation rather than end-to-end, multi-tenant workflow security [6]. Key limitations include:

- Inadequate Security: Weak defenses against prompt injection [3], [4] and an absence of a secure, preview-and-rollback protocol for managing authorized write actions.
- Federated Access Deficiencies: A lack of dynamic, dual-stage RBAC/ABAC query rewriting, which is necessary to guarantee tenant data isolation [5].
- Rigid Data Presentation: Static result rendering that lacks adaptive, intent-informed visual structuring [7] and integrated predictive analytics, such as contrastive time-series anomaly detection [8].

Core Research Gap: There is an acute need for an integrated middleware platform that combines minimal-context SQL generation [1], [2] with deterministic query security [3], [4], federated multi-tenant access control [5], [6], and an adaptive presentation layer equipped with intent-driven predictive analytics [7], [8].

7. Brief description of the solution's nature, including a conceptual diagram (maximum 500

The proposed solution acts as secure AI middleware between natural language inputs and relational databases in a multi-tenant SaaS architecture. It enables organizations to safely embed a chat interface for external end-customers, eliminating the need to develop custom dashboards. To address existing limitations, it introduces a Controlled Write Protocol for safe database updates, implements dual-stage authorization (prompt grounding and AST rewriting) to prevent cross-tenant leakage, and replaces static charting with an adaptive presentation and prediction layer that utilizes query semantics for grounded analytical summaries and confidence-bounded temporal forecasts.

System Perspective (Input, Process, Output):

- **Input:** A user submits a natural language question along with tenant identity, external JWT authentication tokens (e.g., Auth0/Firebase), database schema metadata, role policies, and visualization intent.
- **Process:** The system validates the JWT and extracts user roles. The NL-to-SQL engine retrieves the schema and creates a grounded prompt, injecting permissions directly into AI instructions (first-stage enforcement). The generated SQL undergoes prompt-injection screening, Abstract Syntax Tree (AST) validation, and dangerous-function blocking. The access-control layer applies federated RBAC/ABAC rules, rewriting the AST to guarantee the user only accesses authorized records (second-stage enforcement). For authorized writes, the Controlled Write Protocol previews the transaction, rolls it back, and requires multi-step approval before execution.
- **Output:** Sensitive Personally Identifiable Information (PII) is securely masked. Data is delivered via an adaptive presentation and prediction layer scaling from high-level summaries to grouped views, featuring confidence-bounded forecasts and intelligent caching.

Execution Example:

Four-Component Walkthrough To illustrate the system's nature, consider an external customer of "Tenant A" asking the chat interface: *"Show me my total software expenses for the last quarter and predict the next three months."*

1. **Access Control & Federated Authorization:** This module intercepts the request and validates the external JWT token, establishing the strict tenant isolation boundary and retrieving exact access control policies to ensure the user only views their specific records.
2. **Schema-Aware NL-to-SQL Engine:** This module retrieves Tenant A's specific database schema and intelligently injects authorization rules into the prompt context, translating the intent into a raw SQL query.
3. **AI Query Security & Validation Layer:** Before execution, this middleware parses the SQL into an AST to mathematically verify it is safe. If the request were an authorized update, it would trigger the Controlled Write Protocol. It also applies real-time PII masking to the result pipeline.
4. **Visualization, Presentation & Prediction Layer:** This final layer analyzes the output's semantics and cardinality. Based on classified query intent, it dynamically generates Vega-Lite chart grammars. Where the result set is temporally valid, an integrated prediction engine automatically selects an appropriate forecasting model (e.g., SARIMA, Linear Regression) to generate confidence-bounded forward projections with adaptive anomaly threshold warnings. A unified temporal summarization framework produces mathematically verified text summaries covering both historical facts and predictive outputs, caching results to optimize future interactions.

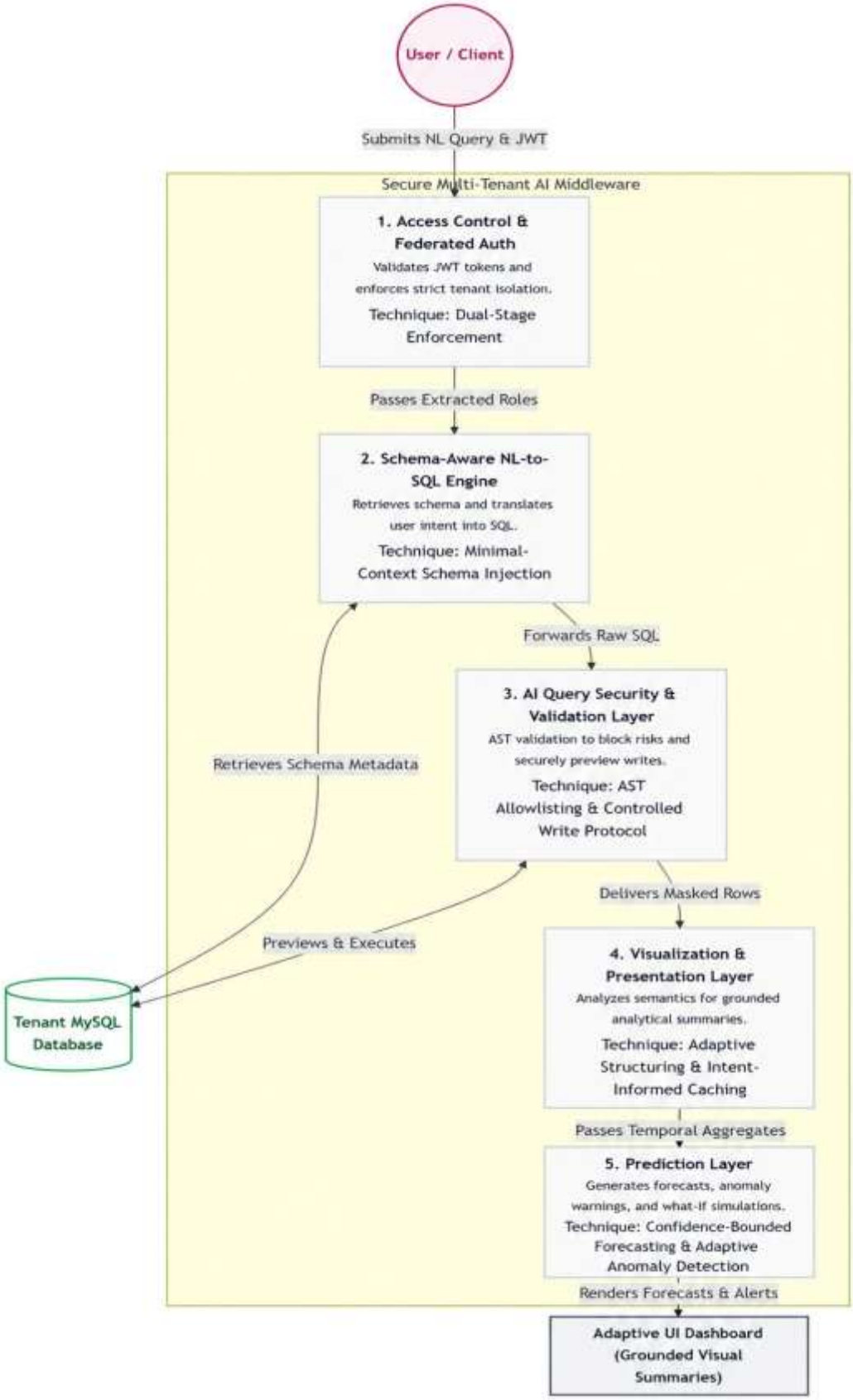


Figure 1. Conceptual diagram of the proposed secure NLIDB workflow.

8. Brief overview of the availability of necessary specialized domain expertise, knowledge, and data. (500 words max)

Specialized Domain Expertise: The team requires deep expertise across four core architectural areas, which will be acquired through focused academic study:

- AI-Driven NLP: Mastering prompt engineering and minimal-schema injection for accurate NL-to-SQL translation.
- Database Security: Analyzing OWASP LLM vulnerabilities, Abstract Syntax Tree (AST) parsing, and transaction rollback protocols.
- Access Control: Researching federated IAM, JWT cryptography, and dynamic RBAC/ABAC policy translation.
- Data Visualization, Presentation & Prediction: Studying structured visualization grammars (e.g., Vega-Lite), forecasting methodologies (SARIMA, Exponential Smoothing), adaptive anomaly detection, and unified grounded summarization.

Technical Knowledge and Skills Acquisition: Practical skills will be gained through iterative prototyping and algorithmic testing using the following stack:

- Backend & Security: Python and Node.js will drive the middleware, utilizing specialized SQL parsers for mathematical AST manipulation and PII masking pipelines.
- Database Management: MySQL will be used to implement strict transaction isolation levels for the Controlled Write Protocol.
- Identity & Frontend: The team will master Auth0/Firebase for external JWT validation, and use React to build the adaptive rendering and prediction interface.
- Prediction & Analytics: Python statistical libraries (e.g., stats models, scikit-learn) will be utilized for intent-driven model selection, IQR/Z-score anomaly detection, and confidence interval computation.

Data Availability and Collection Strategy: To avoid organizational bottlenecks, the project relies strictly on non-proprietary data.

- Public Benchmarks: The NL-to-SQL engine will be trained and evaluated using globally recognized datasets like Spider and BIRD.
- Synthetic Generation: To stress-test the multi-tenant security middleware, PII masking, and prediction engines, the team will generate extensive synthetic MySQL databases simulating realistic Sales, HR, and Finance environments with varying degrees of statistical noise and volatility.

Ethical Considerations: Because the research focuses on system architecture using synthetic and public datasets, formal ethical clearance is not initially required. If future user-acceptance testing (UAT) involves real organizational data, the team will strictly enforce anonymization, obtain informed consent, and secure supervisor approval.

9. Objectives and Novelty

Main Objective

To design, implement, and evaluate a secure, multi-tenant AI middleware framework that translates natural language into accurate SQL via minimal-context schema injection, enforces deterministic query safety and federated tenant isolation through dual-stage authorization and AST validation, and delivers intent-driven, adaptively structured visual analytics with integrated confidence-bounded temporal prediction and grounded unified summarization.

Member Name with Registration No	Sub Objective	Tasks	Novelty
Sasmitha A W D IT23143418	To architect a context-optimized, schema-aware Natural Language-to-SQL translation engine capable of dynamically resolving semantic ambiguities and generating highly	• Dynamically map natural language intent to complex relational database schemas using minimal-context extraction algorithms. • Engineer context-aware prompt management pipeline that optimize LLM token limits while strictly preserving database schema integrity.	The introduction of a minimal-context schema injection and autonomous refinement pipeline that maximizes LLM generation accuracy while strictly minimizing structural database exposure prior to middleware security validation.

	accurate relational queries.	• Develop an automated query refinement loop that utilizes schema-aware feedback to self-correct syntactically invalid or ambiguous SQL outputs. • Resolve structural ambiguities in natural language queries through advanced contextual entity resolution and relationship mapping.	
Navodya P G D IT23144330	To design an AST-driven security middleware that mathematically validates generated queries, prevents prompt-injected semantic attacks, and securely orchestrates preview-based controlled write transactions.	• Develop an Abstract Syntax Tree (AST) parsing engine to mathematically validate query safety and actively block destructive SQL operations. • Engineer a Controlled Write Protocol utilizing database transactional previews and automated rollbacks to safely simulate and verify authorized updates. • Implement advanced Personally Identifiable Information (PII) detection pipelines utilizing Named Entity Recognition (NER) and regex-driven semantic matching.	A defense-in-depth LLM-database gateway combining pre-execution AST allowlisting, dynamic in-pipeline PII masking, and a novel transaction-rollback preview mechanism for governing exceptional multi-tenant writes.

		• Apply real-time, format-preserving encryption and dynamic field masking within the data execution pipeline to ensure GDPR/compliance standards.	
Jinajith R A B IT23212268	To develop a federated, dual-stage access control framework that enforces strict multi-tenant data isolation boundaries through pre-generation prompt grounding and post-generation AST query rewriting.	• Cryptographically validate external federated JWT tokens to establish and maintain strict, mathematically verifiable multi-tenant data isolation boundaries. • Model complex RBAC/ABAC authorization policies and translate them into direct LLM constraints (first-stage prompt grounding). • Engineer dynamic, AST-based query rewriting algorithms to enforce row-level tenant isolation post-generation (second-stage policy enforcement). • Design leakage-aware security constraints to systematically prevent indirect cross-tenant data exposure through aggregate functions or structural inferences.	Moving beyond standard application-level RBAC, this research pioneers a leakage-aware, dual-stage enforcement architecture that translates external JWT claims directly into mathematical query constraints to guarantee multi-tenant isolation.

Wijethunge W M V **IT23256750**	To engineer an intent-driven adaptive, visualization, Presentation and prediction layer that dynamically classifies query semantic intent and result cardinality to generate structured visualizations, confidence-bounded temporal forecasts, grounded unified analytical summaries, and interactive what-if scenario simulations.	• Design an adaptive visualization engine that dynamically generates Vega-Lite chart grammar derived from mathematical query semantics and result cardinality. • Build a formally defined intent-to-prediction mapping algorithm that classifies query intent and automatically selects appropriate forecasting strategies (e.g., SARIMA, Linear Regression). • Implement a data readiness classifier assessing temporal validity, statistical sufficiency, and signal quality of SQL result sets prior to initiating prediction. • Develop a dual-dimension adaptive anomaly detection system using IQR scaling and Z-score normalization to identify historical anomalies and predict future threshold breaches. • Implement a unified temporal summarization framework	A context-aware rendering paradigm that dynamically shifts from static visual mapping to adaptive, progressive data structuring. This is extended by a formally defined intent-to-prediction mapping algorithm, a confidence-bounded lightweight forecasting engine optimized for small multi-tenant business datasets, and a unified temporal summarization framework that mathematically verifies both historical and predictive analytical statements in NL-to-SQL systems, ensuring all summaries and forecasts are strictly grounded in computed model outputs.

		generating mathematically verified statements covering both historical facts and predictive outputs, eliminating hallucination across both temporal dimensions.	

10. This section is to be completed by the Supervisor and the Co-supervisor of the Project.

a) This research topic possesses a comprehensive scope suitable for a final-year project.

Yes	✓	No	

b) The proposed topic exhibits novelty.

Yes	✓	No	

c) The student group can successfully execute the proposed project.

Yes	✓	No	

d) The proposed sub-objectives reflect the students' areas of specialization.

Yes	✓	No	

e) Data required for the project is available.

Yes	✓	No	

f) Any other comments:

Accepted with minor modifications.

	Title	First Name	Last Name	Signature
Supervisor*	Dr.	Dinuka	Wijendra	25/06/2026
Co-Supervisor*	Ms	Thilini	Jayalath	25/6/2026
External Supervisor				
Summary of external supervisor's (if any) experience and expertise				

*- At this stage, identifying the Co-Supervisor is compulsory. Students should reach out to a staff member, with guidance from their supervisor, to serve as the co-supervisor for this project.

SLIIT UNI
THE KNOWLEDGE UNIVERSITY

IT4010 Research Project – 2026 Jul

Topic Assessment Form

This part is to be filled by the Topic Screening Panel members.

Project ID: 347

Acceptable: Mark/Select as necessary

Topic Assessment Accepted	
Topic Assessment Accepted with minor changes (should be followed up by the supervisor) *	✓
Topic Assessment to be Resubmitted with major changes*	
Topic Assessment Rejected. Topic must be changed	

* Detailed comments given below

Comments

The Review Panel Details

Member's Name	Signature	Date
Mr. Jagath		06/07/26
Ms - Dilani		06/07/26

*Important:

1. According to the comments given by the panel, make the necessary modifications and get approval from the Supervisor or the Same Panel.
2. If the project topic is rejected, identify a new topic, and follow the same procedure until the topic is approved by the assessment panel.